

摘要：

AI资讯网站AIHOT周末遭两轮猛烈攻击，运营者虽是纯外行，却借助Claude Fable 5联手防御，边打边学，接连上线封IP、限流、加固缓存等策略。鏖战48小时后网站恢复稳定，而AI在这场攻防中如同一位真正的合伙人，自主分析、果断处置。

这个周末，可能是我最戏剧性的周末了。

周五发完Claude Fable 5的文章之后，看的人还是蛮多的，大家反馈也都不错。

但是呢，我也不知道触动了谁，也有可能是某些大佬，可能想让我长长教训，或者想让我知道，Vibe Coding的网站就是狗屎，是有无数的安全隐患的。

然后，对我的这么个破逼看AI资讯的网站AIHOT，进行了长达两天的攻击。。。

我被迫拿起AI，用极为蹩脚的知识，与他们展开了攻防。

后来我还发了个感慨，果然是干中学，这两天的时间，可能是我对于网络安全的学习速度提升的最快的两天了。。。



故事是这样的。

上周六，因为前一天周五的时候，搬家搬了一整天，有点累，加上AIHOT服务器也没啥异动，我就睡得比较早，大概凌晨2点就去睡了（我正常一般都是4点左右）。

然后，噩梦就开始了。

后来我是复盘我们服务器的日志，才看到这一切的。

周六凌晨4点48分20秒，在我熟睡的时候。

一个来自德国机房的IP，来到了我的AIHOT网站，请求了一张图片。

因为我的网站上，为了大家的用户体验，所以很多的图片，我都提前缓存下来了，大概就像这样。



我的服务器认认真真接待了它，把这张压缩过的86k的图片给它返回了过去。

事后看，这其实就是个踩点，后来我复盘才看清它的打法。

这个德国的IP，做了一个脚本，手里拿着一份提前爬好的清单，上面全是我们的页面里真实存在的图片链接，它照着清单，一条一条地试，确认哪些链接能让我的服务器真的跟他进行交互给它返回数据。

这个德国IP的请求的身份标识栏里，没有伪装成服务器，没有伪装成爬虫，只有一行字：

#TeamAntiAI

这个翻译过来就是，反AI小队。

我之前以为是某个组织，但是周末查了一下以后发现，全网都没有这个反AI小队的任何信息，大概率，就是某一个大佬自己标的。

目的特别单纯，就是打垮我这种vibe coding做的网页，让我这种外行吃吃教训，让我们知道，不是谁都可以做网站对外提供服务的。

你敢对外，我就打死你。

凌晨5点半，攻击正式开始了。

对我服务器的请求量开始陡峭地往上爬。

5点58分的时候，一分钟直接请求了13万次。

6点整，我服务器的报错日志开始出现了第一个报错，翻译成成人话就是，他请求的太猛了，我的AIHOT，完全接待不过来了。

然后是早上6点04分到6点07分。

这4分钟，它往我的图片接口灌了236万个请求。

峰值出现在6点05分，那一分钟，直接灌了87万次。

我的站按过去一个月的数据算，平时一天的请求量是三百多万，平均到每分钟，也就两千多次。



而这一分钟，直接打了我平时的340倍。

整个上午它没停过手，一波一波的，到中午我起床为止，总共砸了大概1100万个请求。

而这一切发生的时候，我正在睡觉。

等我睡醒，看到铺天盖地的用户反馈，同时看到飞书群的告警、反应过来的时候，网站已经炸了，用户打开时不时就会报错，Skill和API啥的动不动就是失败。

我翻着日志里那些密密麻麻的攻击记录，每一行都顶着同一个签名，#TeamAntiAI。

```
text
[{"time": "2023-07-04 13:14:20", "ip": "192.168.1.1", "user_agent": "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/115.0.0.0 Safari/537.36", "path": "/api/skill", "status": 404, "message": "Not Found"}]
```

这里简单的提一下，这个所谓的签名，其实就是署名，放在HTTP的一个User-Agent里，这个User-Agent本来是浏览器和爬虫告诉服务器我是谁的地方，比如Chrome、GPTBot、Googlebot等等，所以呢，攻击者留下这个署名，用意也很简单。

就是纯粹的挑衅，以及传达态度，然后教育我。

我也是挺崩的。

也不知道招谁惹谁了。

我醒了以后，看到这些，没办法，第一时间在AIHOT的飞书订阅群里发了通知，跟大家说明了一下情况。



还有一个最根本的问题，我不是开发，更不是安全工程师，作为一个设计师出身的纯粹的外行，你让我去排查线上的攻击，我说实话，那跟让我去修飞机也没啥区别。

所以呢，为了解决这个问题，让我的网站还能正常提供服务，我只能祭出AI了，你不是反AI小队吗，那就跟Claude Fable 5打一打吧。。。

于是，我就跟我的Claude Fable 5说：

我们被攻击了，目标只有一个，在不误伤真实用户的前提下，把攻击挡住。然后进行全方位的修复。

作为一个纯粹的外行，我只能这么干了。

但坦诚的讲，接下来的48小时，可能是我学习速度最快的48小时，因为我不可能当个傻子，真的全部让渡给AI，所以，它一边分析，我一边学习，所有的思考过程，有任何我不懂的专业名词和做法，我就立刻截图扔给Codex，让它根据我的AIHOT这个项目，给我用大白话进行解释。

相信我，当你的服务器持续的崩，你的域名账单持续的烧钱的时候，你的学习欲望，一定是最强烈的时候。。。

Claude Fable 5在扒了半天以后，给了我一个让我非常意外的结论。

它说，我的站，其实没被打穿，我的服务器防护做的非常的好。

那将近240万个打向AIHOT图片接口的请求，被我们之前配好的限流器结结实实挡住了，日志里的数据非常漂亮，239万次拒绝，放进来的只有最开始踩点那一千来个，拦截率做到了百分之九十九点九五。

那我懵逼了，那我的服务器是怎么崩掉的？？？

然后Fable 5说，真正出事的，是我们服务器另一个地方。

这里得先交代一下我们这台服务器的特殊性，不然大家可能会看不懂这个坑是怎么冒出来的。

我在火山上买的这台服务器，其实现在是我们公司的共享服务器，上面跑着三十多个项目。

因为之前为了让公司同事都能享受Vibe Coding的快乐，所以，我把这台服务器的整套部署流程，包装成了一个Skill，效果特别好。

同事不需要懂任何开发知识或者运维，只需要跟AI说一句“帮我把这个项目部署上去”，AI自己连服务器、做隔离、建服务、自建域名，几分钟，项目就能正式上线了。

但现在回头看，几个月前，我给大家封装那个Skill的时候，脑子里只有一个词，方便。

那个时候，安全这个维度，压根不在我的需求清单里。

那个时候还是Opus 4.6的时代，我没提，AI就没做。

于是呢，每个项目就像一扇扇的门，每一扇新开的门，都开得飞快，但没有一扇门配了锁。

我自己的AIHOT自己的限流，是我之前单独做安全硬化的时候加的，等于三十多个项目里，就我自己这个项目，做了防护。

攻击者把整台服务器试了一圈，就发现了这个事。

我的图片接口，从aihot的域名进来，有限流，发现攻击不了。



但是，它硬生生找到了另一个当时没有设防的别的项目的域名。

于是，直接往那个域名中，爆破了868万个请求。

这868万个请求瞬间把整台服务器的并发连接占满了，我的nginx当时的并发上限，一共就768个。

你可以理解成整台服务器同时只能张开768只手，现在全被攻击者握住了，真实用户伸过来的手，就完全没人理他了。

于是，握手不成功，于是就是在用户视角里，全站瘫痪，当时看了一下，周六的早上，间歇性报错了1万多次。

说实话，看到这个分析，我都懵逼了，因为我其实一直自认为是一个非常谨慎的人，AIHOT现在流量也还挺大的，所以我对着AIHOT，加了非常非常多的防护，但是如果不是Claude Fable 5帮我分析，我是真的不知道，我那个服务器上其他人的项目上，还有那么多的坑。

然后就是正常的封禁IP、加限流，往服务器上做安全中台，对所有项目进行全域防护。

virxact-shield 安全中台已全量上线 

同时在这个过程中，Claude Fable 5也在全面审查以后，自主的发现了我们服务器还有AIHOT上的一些安全漏洞和可以优化的点，这全都是以前Opus 4.8还有GPT-5.5在审查的时候，没有查出来的。

周六下午提交了很多的防护以后，看了一眼日志，又让AI扫了一遍，基本上流量和稳定性都回到了正常，我本来觉得这事就翻篇了。

结果，我想多了。

周六深夜12点多的时候，我洗完澡回来，发现我们飞书反馈群，忽然炸了。

我们AIHOT网站上有用户反馈功能，用户提交的反馈会自动推送到我的飞书群里，方便我去看大家的反馈，以及判断是不是要优化。

那天晚上开始，群里的推送莫名奇妙的冒出了上万条，我看了一眼，人都傻了，点开全是纯数字乱码，落款是一堆伪造的QQ邮箱。

这个攻击者老哥，盯上了反馈接口。

一个北京联通的IP，以每秒5.5次的频率，往我们的反馈接口灌垃圾数据。

而且这个频率，是精心挑选过的，正正好踩在限流的下沿一点点。

直接给我的数据库里灌了3万多条垃圾数据，我的飞书直接爆炸了。

真的就是纯粹的恶意。。。

而这还只是开胃菜。

凌晨12点半，主力正式到场。

一批新IP加入进来，有云服务器，有居民宽带，跟第一波单枪匹马的莽夫画风完全不同，这一次是多IP协同，而且每个IP的请求频率都精准的压在限流红线之下，单看谁都不违规，但是合起来，就是一支军队。

而且这次，大部分都不打#TeamAntiAI的旗号了，全部伪装成各种普通的用户，开始批量攻击。

打法也升级了，他们专挑最贵的页面，就是那种没法用缓存、每次都要服务器现场渲染的页面，而且每个请求都带一个随机参数，这个随机参数是用来骗缓存的，缓存一看参数不一样，以为是新页面，就放请求进去让服务器重新算。



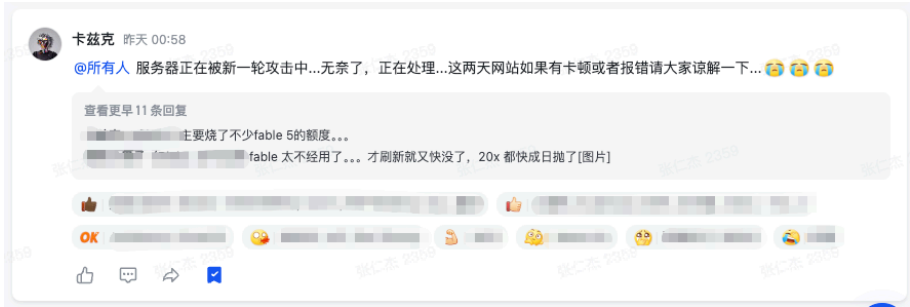
于是，我服务器后台的渲染队列很快就堵死了。

我当时甚至看到日志里有一条真实用户的请求，加载一个列表页，等了60.024秒。

60秒。。。

真的，平时这个页面，40毫秒就出来了，连1秒都用不到，直接慢了一千五百倍。

没办法，只能在飞书群里又给大家磕头。



然后Claude Fable 5开始同步的防御。

那天晚上的git提交记录，我现在回看，还是会觉得感慨。

凌晨0点56分，AI封掉往反馈接口灌水的IP，给反馈接口加上独立的防灌水规则，飞书群安静了。

1点17分，给埋点接口加上限流，堵住另一个同样能被灌的口子。

1点36分，7个证据确凿的攻击IP拉黑。

那几个攻击的IP拉黑的那一刻，列表的响应时间终于从60秒跌回了40毫秒。

1点51分，开始治本，一整套缓存加固上线，这一条是当晚真正的胜负手。

它先改了缓存的识别规则，让缓存彻底无视那个随机参数，从此参数再怎么随机，命中的都是同一份缓存，堵上了之前的漏洞。

然后把缓存时间从60秒拉长到3分钟，因为我们是个资讯站，大部分时间其实都是静态的，列表页3分钟前的样子和现在的样子，几乎没区别，但对服务器来说，同一个页面被真正重新渲染的次数，直接除以3，进一步优化性能。

然后做了合单，同一时刻涌进来一百个人要同一个页面，以前是后厨炒一百遍，现在只放第一个请求进去炒，剩下九十九个在窗口等着，炒好了一起分，继续做性能优化。。。

2点15分，它把系统里所有的报警消息全部重写了一遍，从工程师黑话，改成产品经理能看懂的人话。

因为它知道，半夜看报警的人，是我，之前我提了一下我有点看不懂文案。

然后，它还把封禁审批的流程改了，之前的Claude Opus 4.8开发的规矩是每个封禁因为怕误封，都要我拍板，但它同样的，发现我根本看不懂那些证据，IP归属、请求指纹、行为特征，我

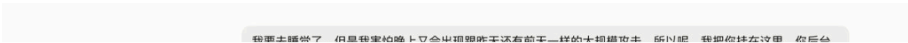
盯着看半天也只能凭感觉。

所以它直接拉了最近两个月以来的恶意IP的特征，列出了6条，做了自动化封禁策略，保证不伤真人用户的同事，自动化的Ban掉所有的恶意IP。

2点40分，把访问日志的留存拉长到一年，理由是，为了可能取证需要。

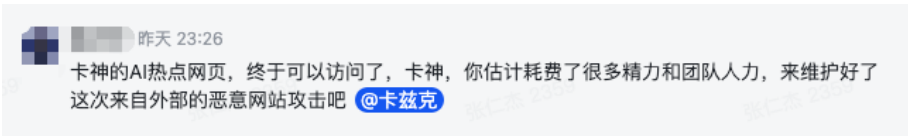
最后，顺手还挖出了一些长期潜伏的盗采爬虫，无时无刻的不在爬我们的数据做了镜像站，Claude Fable 5在核实完特征以后全封了。。。

一切搞定，大概凌晨3点了，我害怕又出现凌晨5点多的大规模攻击导致我服务器崩了，然后又账单爆炸，于是我跟Claude Fable 5说，我要去睡觉了，你帮我盯着。。。



所幸，一夜平安无事，所有的攻击，全都防住了。

昨天晚上，看到用户给我评论。



还是挺感慨的。

哪有啥团队，就我一个人+一个AI。

我还是个纯外行，纯小白，能做的，就是告诉Claude Fable 5，发生了啥，用户反馈了啥，快去帮我处理。

我以前打过一个比方，说不同档次的模型，用起来完全是三种东西。

差一点的模型，像一个非常初级的执行者。你得把方案想得明明白白，prompt写得事无巨细，它只负责纯粹地干活，你漏想一步，它就错一步。

好一点的模型，比如GPT 4.8、GPT 5.5这一档，像一个组长，或者初级总监，你给它一个大概的任务，它能自己拆解，做出来的东西有的时候会比你自己想的全面一些。

而这两天一直在用的Fable 5，我觉得，是另一个物种。

它像一个高级总监，甚至合伙人。

你不需要给它方案，甚至不需要给它任务，你只需要给它目标。



我这两天给它的目标就一句话：在不误伤真实用户的前提下，把攻击挡住。

最后交回来的东西，比我自己能想象出来的上限，还要高，至少在我这个外行的眼里，一切都做的井井有条，多想一步，全力的解决所有的问题。

给执行者，你要写一页纸的说明书。

给组长，你要交代一段话。

给合伙人，你只需要说清楚你要什么，和什么不能碰。

我越来越感受到，模型越强，prompt越短。

你需要定死的，就是目标与红线，这其实，对应在Agent里面的，就是Goal和Harness。

这两天，真的让我成长很多，学到了太多了，一边被攻击，一边恶补网络安全知识，一边防守。

这两天我搞明白了限流、封禁IP、缓存击穿、应用层攻击和带宽攻击的区别、为什么防守要一层一层设。

没有一个是看教程学的。

这种学习效率，我说实话，我过去从来没体验过。

以前自学一个新领域，最大的成本其实就是不知道该学什么，教程会把一百个知识点平铺在你面前，个个都显得挺重要。

但实战里，每个知识点登场的时候，他其实，都带着一个正在流血的伤口，你想不记住都难。

这可能就是最大的进化了。

网站现在还在跑着。

我也不知道，下一波攻击什么时候会再来。

我只能说，谢谢大佬们，给我学习的机会。

本文来源：[数字生命卡兹克](#)

风险提示及免责条款

市场有风险，投资需谨慎。本文不构成个人投资建议，也未考虑到个别用户特殊的投资目标、财务状况或需要。用户应考虑本文中的任何意见、观点或结论是否符合其特定状况。据此投资，责任自负。

* 体验资格每人限申领一次

扫码
免费领取

VIP会员·7天畅读卡 | 大师课·入门串讲



限免



写评论

请发表您的评论

 表情  图片

发表评论